ISSUE 日本語解説資料

Issue #54 GCP security baseline を定義する

GitHub で closed になっている issue 記録を、そのまま参照用 PDF に変換したもの。

Issue #54　更新: 2026/03/12　ソース: docs/portal/issues/issue-54-gcp-security-baseline.md

GitHub: https://github.com/PLAYER1-r7/MultiCloudProject/issues/54

計画　portal　セキュリティ　GCP

この ISSUE の要点

Issue 47 で GCP support の first step は preview/static delivery baseline に限定され、Issue 48 から Issue 53 で architecture、IaC、workflow、DNS/operator boundary、resource/workflow execution scope も fixed された。しかし現時点では、GCP preview path で最低限どの security control を release blocker として扱い、どの control を provider-specific hardening として後続に残すかが current issue chain として固定されていない。このままだと、Cloud Armor、security headers、

目標

GCP security baseline の議論たたき台を作り、preview/static delivery path に必要な browser-facing control、operator-facing control、reviewable evidence、非対象、open questions を small-scope で整理する。

完了状態

ISSUE CLOSED

Cloud Audit Logs、Secret Manager rotation path、preview credential boundary が実装着手のたびに再解釈され、workflow / resource execution の fail-closed 条件が security 観点で揺れやすい。

1. この Issue が扱っていたこと

まず Summary と Goal から、この Issue が何を決めるためのものだったかを短く押さえる。

Issue 47 で GCP support の first step は preview/static delivery baseline に限定され、Issue 48 から Issue 53 で architecture、IaC、workflow、DNS/operator boundary、resource/workflow execution scope も fixed された。しかし現時点では、GCP preview path で最低限どの security control を release blocker として扱い、どの control を provider-specific hardening として後続に残すかが current issue chain として固定されていない。このままだと、Cloud Armor、security headers、Cloud Audit Logs、Secret Manager rotation path、preview credential boundary が実装着手のたびに再解釈され、workflow / resource execution の fail-closed 条件が security 観点で揺れやすい。

目標

GCP security baseline の議論たたき台を作り、preview/static delivery path に必要な browser-facing control、operator-facing control、reviewable evidence、非対象、open questions を small-scope で整理する。

2. 完了判断の見方

Tasks、Definition of Done、Current Status の記述から、どこまで完了済みとして扱っているかを先に読む。

TASKS

4/4 項目が完了済みとして記録されている。

DEFINITION OF DONE

4/4 項目が完了済みとして記録されている。

ISSUE CLOSED / GitHub Issue: #54 / GitHub URL: https://github.com/PLAYER1-r7/MultiCloudProject/issues/54 / Sync Status: local close note updated and GitHub issue

> body resynced before closing / Close Status: GitHub issue closed; local record retained as final reference / local issue record として GCP security baseline の議論たたき台を追加した / preview/static delivery path の minimum security control、credential boundary、fail-closed 条件を Resolution として固定した / Issue 52 / 53 の implementation と validation により、この baseline が参照する workflow / resource execution evidence path は live state で確認済みである

3. 依存関係と読み進め方

Dependencies や前提 Issue がある場合は、ここで関連先を先に把握しておくと読みやすい。

依存関係

- Issue 11
- Issue 47
- Issue 48
- Issue 49
- Issue 50
- Issue 51
- Issue 52
- Issue 53

読み方の注意

この解説書は原文の意思決定や完了状態を読みやすくするための補助資料である。最終的な正本は原文 Issue にあり、判断変更時は原文側を先に更新する。

4. 用語集

原文に残る英語や実務用語のうち、訳し切らずに補助説明を付けた方が読みやすい語をここにまとめる。

原語	日本語の扱い	補足
fail-closed	安全側で失敗させる	判定できない場合に成功扱いせず、明示的に停止または失敗として扱う設計方針。
baseline	基準線	後続作業が参照する最小限の判断・実装・検証の出発点。
hardening	堅牢化	既存機能を壊れにくくし、運用や検証の安全性を高める作業。

原語	日本語の扱い	補足
production	本番環境	実際の利用者に公開される運用環境。
operator	運用担当者	監視、承認、非表示、切り戻しなどの運用行為を担う役割。
workflow	ワークフロー	GitHub Actions などで定義された自動処理の流れ。
owner	責任者	意思決定または更新責任を持つ担当者。文脈により product owner などを含む。
review	レビュー	内容や実装が要件を満たすか確認する工程。
evidence	証跡	判断や完了状態の根拠になるログ、表、文書、出力結果。
draft	下書き	まだ確定前だが議論やレビューの基礎として置かれた文書。
release	リリース	利用者に公開するまとまりとしての提供単位。
rollback	ロールバック	変更後の状態から以前の安定状態へ戻すこと。
current status	現在の状態	Issue 文書時点での完了度合いや同期状況を示す節。
definition of done	完了条件	その Issue を完了とみなすために満たすべき条件。
task contract	タスク契約	対象、目的、スコープ、検証計画、リスクを明文化した作業契約。

5. 原文

以下に Issue 原文をそのまま掲載する。詳細な根拠、証跡、チェックリストはこの原文を参照する。

概要

Issue 47 で GCP support の first step は preview/static delivery baseline に限定され、Issue 48 から Issue 53 で architecture、IaC、workflow、DNS/operator boundary、resource/workflow execution scope も fixed された。しかし現時点では、GCP preview path で最低限どの security control を release blocker として扱い、どの control を provider-specific hardening として後続に残すかが current issue chain として固定されていない。このままだと、Cloud Armor、

security headers、Cloud Audit Logs、Secret Manager rotation path、preview credential boundary が実装着手のたびに再解釈され、workflow / resource execution の fail-closed 条件が security 観点で揺れやすい。

目標

GCP security baseline の議論たたき台を作り、preview/static delivery path に必要な browser-facing control、operator-facing control、reviewable evidence、非対象、open questions を small-scope で整理する。

タスク契約

タスク契約

メタデータ
- タスク ID: ISSUE-54
- タイトル: GCP security baseline を定義する
- 依頼者: repository owner
- 担当者: AI agent
- 対象アプリ: portal-web
- 対象環境: future GCP preview security planning
- 優先度: 中
- 先行条件: Issue 11 closed, Issue 47 resolved, Issue 48 resolved, Issue 49 resolved, Issue 50 resolved, Issue 51 resolved, Issue 52 resolved, Issue 53 resolved

目的
- 解決する問題: GCP preview architecture と execution scope は fixed したが、preview domain、edge protection、security headers、audit trail、credential boundary、reviewable security evidence をどこまで first-step baseline として固定するかが未整理のままだと、resource execution と workflow implementation の release blocker が security 観点で曖昧なまま残る
- 期待する価値: GCP preview path の security baseline を browser-facing control、operator-facing control、reviewable evidence、scope boundary の単位で整理し、Issue 53 と Issue 52 の implementation step が参照できる minimum security contract を作れる

スコープ
- 含むもの: HTTPS / managed certificate baseline、security headers baseline、Cloud Armor の minimum posture、Cloud Audit Logs と execution evidence の接続、preview credential / secret boundary、security review evidence、open questions table の作成
- 含まないもの: Cloud Armor rule tuning 実装、IAM hardening 実装、Secret Manager 実設定、security scanner / SCC / SIEM 導入、24x7 incident response 設計、runtime app auth の導入
- 編集可能パス: docs/portal/issues/issue-54-gcp-security-baseline.md
- 制限パス: apps/portal-web/**, infra/**, .github/workflows/*.yml, closed issue records except explicit evidence references

受け入れ条件
- [x] 条件 1: GCP preview security baseline の control set と scope boundary が文書から一意に読める
- [x] 条件 2: browser-facing control、operator-facing control、reviewable evidence の責務分離が整理されている
- [x] 条件 3: provider-specific hardening 実装や security operations depth を混ぜず、preview baseline に限定できている

実装計画
- 変更見込みファイル: docs/portal/issues/issue-54-gcp-security-baseline.md
- アプローチ: Issue 11 の security baseline、Issue 47 の GCP baseline judgment、Issue 48 の architecture baseline、Issue 49 の IaC contract、Issue 50 から Issue 53 の workflow/resource execution contract を接続し、GCP preview security baseline を control、evidence、owner boundary の 3 観点で整理する

```
- 採用しなかった代替案と理由: resource 実装時に都度 security を判断する案は stop condition が drift しやすいため採らない。逆に IAM hardening、security tooling、24x7 response design まで同一 issue に含める案も first-step preview baseline としては重すぎるため採らない

検証計画
- 実行するテスト: markdown review; get_errors on edited files
- 確認するログ/メトリクス: security control wording、preview credential boundary wording、reviewable evidence wording、non-goal wording の整合
- 失敗時の切り分け経路: docs/portal/issues/issue-11-security-baseline.md、docs/portal/issues/issue-47-gcp-baseline-design.md、docs/portal/issues/issue-48-gcp-architecture-baseline.md、docs/portal/issues/issue-49-gcp-iac-topology-and-state-backend-judgment.md、docs/portal/issues/issue-50-gcp-deploy-workflow-baseline.md、docs/portal/issues/issue-51-gcp-preview-domain-certificate-dns-operator-memo.md、docs/portal/issues/issue-52-gcp-preview-workflow-execution.md、docs/portal/issues/issue-53-gcp-preview-delivery-resource-execution.md を照合し、control set、evidence path、scope boundary のどこが欠けているかを分ける

リスクとロールバック
- 主なリスク: security baseline の記録が Cloud Armor rule 実装済み、IAM hardening 済み、または 24x7 security operations が存在するかのように誤読されること
- 影響範囲: GCP preview resource execution、workflow implementation prerequisite、operator handoff、release blocker judgment
- 緩和策: wording を HTTPS、security headers、edge protection baseline、audit trail、credential boundary、reviewable evidence に限定し、tooling depth と operational maturity は follow-up に残す
- ロールバック手順: scope が広がりすぎた場合は browser-facing control と credential boundary だけを残し、Cloud Armor tuning、IAM hardening、security tooling は別 issue に切り出す
```

作業項目

- [x] GCP preview の browser-facing security baseline を整理する
- [x] operator-facing credential / secret boundary を整理する
- [x] reviewable security evidence と release blocker を整理する
- [x] security baseline の非対象と open questions を整理する

完了条件

- [x] HTTPS、security headers、edge protection、audit trail の minimum baseline が読める
- [x] preview credential / secret boundary と managed path の前提が読める
- [x] security evidence と fail-closed 条件が workflow / resource execution と接続して読める
- [x] provider-specific hardening depth が本 issue 非対象として維持されている

Initial Notes

- Issue 11 は first-release security baseline として HTTPS、security headers、managed secrets、audit logging、no wildcard CORS in production を基準に置いている
- Issue 47 は GCP first step を preview/static delivery baseline に限定し、security / observability / rollback は user-facing availability と reviewable evidence を主語にする judgment を fixed している

- Issue 48 は GCP preview architecture の第一候補を Cloud Storage + global external HTTPS load balancer + Cloud CDN + Cloud Armor + Google-managed certificate に固定している
- Issue 49 は OpenTofu standard、environment separation、usage-oriented output naming、backend judgment の切り分けを fixed している
- Issue 50 から Issue 53 は reviewed target reference、certificate-related reference、resource_execution_reference、blocked pending state を fail-closed contract として固定している

Issue 54 Discussion Draft

このセクションは、GCP security baseline を議論するためのたたき台である。ここで決めたいのは preview/static delivery path に必要な minimum security baseline であり、まだ決めないのは IAM hardening depth、security tooling integration、24x7 incident response design、runtime application auth である。

1. 今回の論点をどこまでに限定するか

提案:

- この issue は `GCP preview delivery path で release blocker として扱う security baseline を何に置くか` に限定する
- browser-facing control と operator-facing control を分ける
- preview proof に必要な minimum baseline と later-phase hardening を分ける

2. browser-facing control の第一案

提案:

- public entry は HTTPS を正規経路とし、preview domain は reviewed certificate path を前提にする
- security headers は delivery layer で管理し、app code の ad hoc 実装に寄せない
- user-facing route は `preview.gcp.ashnova.jp` を前提に一意に review できる path に固定する

3. edge protection と certificate posture の第一案

提案:

- Cloud Armor は preview path の minimum edge protection baseline として扱う
- Google-managed certificate は reviewed certificate-related reference と一緒に fail-closed に確認する
- certificate / target state が pending の間は security baseline 未成立として deploy / operator handoff と切り分ける

4. audit trail と reviewable evidence の第一案

提案:

- security-relevant change の正規証跡は GitHub workflow/resource execution record と Cloud Audit Logs を組み合わせる
- reviewed evidence には selected commit、resource execution reference、preview public URL、reviewed target reference、certificate-related reference を含める
- provider resource id だけでなく operator-facing reference を主語にする

5. credential / secret boundary の第一案

提案:

- preview credential と secret は repository や frontend bundle に置かない

- GitHub environment secret / variable は preview 専用 scope を前提にし、production と混在させない
- runtime secret が必要になる場合のみ managed secret path を追加し、現段階では static delivery path に不要な secret を増やさない

6. release blocker と fail-closed 条件の第一案

提案:

- missing HTTPS enforcement、security headers 未定義、reviewed certificate reference 不足、resource execution evidence 不足は release blocker とする
- pending certificate / target state が operator hold 条件なら security baseline 未成立として扱う
- preview proof では broad CORS、unreviewed public access、unowned secret path を許可しない

7. 今回は決めないこと

- Cloud Armor rule set の深い tuning
- IAM role / service account の詳細 hardening
- Secret Manager 実設定や rotation automation
- security scanner、SCC、SIEM、24x7 incident response
- future API / auth 導入後の access control design

8. 後続 issue とどう接続するか

- resource execution step は Cloud Armor、certificate-related reference、preview public URL を security evidence の一部として残す
- workflow implementation step は build provenance と resource provenance に加え、security baseline 成立前提を fail-closed に扱う
- monitoring / rollback follow-up は security baseline を前提に signal と recovery boundary を定義する

9. この場で確認したい論点

Resolution を書く段階では、この表の `Resolution 確定文言` 列を埋めてから使うこと。

論点	判断方向（Discussion 時点の仮）	Resolution 確定文言
GCP preview security baseline を preview/static delivery path に限定してよいか	yes。preview proof に必要な minimum control に留める	`GCP preview security baseline は preview/static delivery path に必要な minimum control に限定し、IAM hardening depth、security tooling integration、24x7 incident response design は後続 issue に分離する`
browser-facing baseline に何を含めるか	HTTPS、security headers、reviewed preview domain/certificate を第一候補にする	`browser-facing baseline は HTTPS、delivery layer で管理する security headers、reviewed preview domain / certificate を minimum control とする`

論点	判断方向（Discussion 時点の仮）	Resolution 確定文言
edge protection baseline を何に置くか	Cloud Armor を minimum edge protection baseline とする	`edge protection baseline は Cloud Armor を minimum edge protection baseline として扱う`
audit trail の正規経路を何に置くか	workflow/resource execution evidence と Cloud Audit Logs を組み合わせる	`audit trail の正規経路は workflow / resource execution evidence と Cloud Audit Logs を組み合わせる`
preview credential / secret boundary をどう置くか	preview 専用 GitHub environment scope と managed secret path 前提にする	`preview credential / secret boundary は preview 専用 GitHub environment scope と managed secret path 前提に置き、repository や frontend bundle に secret を置かない`
pending certificate / target state をどう扱うか	security baseline 未成立として fail-closed に止める	`pending certificate / target state が残る場合は security baseline 未成立として扱い、deploy / operator handoff は fail-closed に止める`

Resolution

Issue 54 の判断結果は次の通りとする。

- GCP preview security baseline は preview/static delivery path に必要な minimum control に限定し、IAM hardening depth、security tooling integration、24x7 incident response design は後続 issue に分離する
- browser-facing baseline は HTTPS、delivery layer で管理する security headers、reviewed preview domain / certificate を minimum control とする
- edge protection baseline は Cloud Armor を minimum edge protection baseline として扱う
- audit trail の正規経路は workflow / resource execution evidence と Cloud Audit Logs を組み合わせる
- preview credential / secret boundary は preview 専用 GitHub environment scope と managed secret path 前提に置き、repository や frontend bundle に secret を置かない
- pending certificate / target state が残る場合は security baseline 未成立として扱い、deploy / operator handoff は fail-closed に止める

この合意で明確になること:

- GCP preview path で最低限守る security baseline は browser-facing control、edge protection、audit trail、credential boundary の単位で固定される
- Cloud Armor や reviewed certificate reference は architecture 上の候補ではなく release blocker judgment に接続する minimum baseline として扱える
- workflow / resource execution が残す evidence は security review でもそのまま参照でき、build provenance と resource provenance に security baseline を接続しやすくなる
- preview credential と secret は production から分離した scope を前提にでき、unowned secret path や accidental secret exposure を baseline 時点で排除できる

- pending certificate / target state は security baseline 未成立として扱うため、preview proof を security 未確認のまま先へ進めない fail-closed 条件を維持できる

後続 issue への引き継ぎ事項:

- resource execution step では Cloud Armor、preview public URL、reviewed target reference、certificate-related reference を security evidence の一部として execution record に残す
- workflow implementation step では build provenance と resource provenance に加え、security baseline 成立前提を fail-closed 条件として扱う
- monitoring / alert routing baseline では security baseline 成立後の user-facing signal と operator hold 条件を first-response path に接続する
- rollback and recovery memo では security baseline 未成立時の safe stop と post-recovery verification の境界を整理する

プロセスレビュー記録

- Section 9 の open questions は `Resolution 確定文言` 列を埋めたうえで本 Resolution に統合した
- 本 issue の judgment は preview security baseline の固定であり、Cloud Armor rule tuning、IAM hardening、Secret Manager 実設定、security tooling integration は依然として後続 issue の対象である
- GitHub Issue #54 の body は local issue record の最新版へ再同期する前提で扱う

現在の状態

- ISSUE CLOSED
- GitHub Issue: #54
- GitHub URL: https://github.com/PLAYER1-r7/MultiCloudProject/issues/54
- Sync Status: local close note updated and GitHub issue body resynced before closing
- Close Status: GitHub issue closed; local record retained as final reference
- local issue record として GCP security baseline の議論たたき台を追加した
- preview/static delivery path の minimum security control、credential boundary、fail-closed 条件を Resolution として固定した
- Issue 52 / 53 の implementation と validation により、この baseline が参照する workflow / resource execution evidence path は live state で確認済みである

依存関係

- Issue 11
- Issue 47
- Issue 48
- Issue 49
- Issue 50
- Issue 51
- Issue 52
- Issue 53